

Northline Brokerage Services, Inc.

Regulation S-P Privacy, Safeguards, and Breach Response Policy

Document owner	Chief Compliance Officer
Approved by	Management Compliance Committee
Effective date	March 3, 2026
Version	2.7
Classification	Internal Policy - Fictional Test Document

This fictional document is part of the RegSpan realistic testing corpus. It is written as an ordinary company policy, not as a model answer or legal opinion.

Document Control

Version	Effective date	Summary of change	Approval
2.7	March 3, 2026	Current approved issue	Management Compliance Committee

Policy Overview

Northline operates a retail brokerage platform, branch-office network, online customer portal, and clearing relationship with several technology and data vendors.

The sections below describe the firm's approved practices. Department procedures may provide additional implementation detail.

1. Purpose, Scope, and Applicability

Northline operates a retail brokerage platform, branch-office network, online customer portal, and clearing relationship with several technology and data vendors.

This document establishes the firm's internal approach to protecting customer information and responding to information-security events. It applies to employees, temporary personnel, contractors, offices, information systems, paper records, and relevant service-provider relationships.

Business units may maintain more detailed procedures, but those procedures may not reduce the protections stated here. Legal and Compliance interpret regulatory obligations and resolve conflicts with other retention, privacy, cybersecurity, or contractual requirements.

2. Definitions

Term	Working definition
Customer information	A record containing nonpublic personal information about a customer of a financial institution, including information handled by or on behalf of the firm and information provided by another financial institution about its customers.
Sensitive customer information	Customer information whose compromise could create a reasonably likely risk of substantial harm or inconvenience to an identified individual.
Customer information system	Information resources and related infrastructure used to collect, process, maintain, use, share, disseminate, or dispose of customer information.
Service provider	A person or entity that receives, maintains, processes, or is permitted access to customer information through services provided directly to the firm.
Incident	Unauthorized access to or use of customer information, or an event reasonably likely to involve such access or use.

3. Roles and Responsibilities

Role	Core responsibilities
Executive sponsor	Provides authority, resources, and escalation support.
Incident Response Lead	Directs triage, response activities, documentation, and closure.
Information Security / Technology	Investigates, contains, restores, and validates systems.
Compliance and Legal	Interprets notice, recordkeeping, regulatory, and law-enforcement obligations.
Business and data owners	Identify affected processes, systems, information, and customers.
Service-provider owner	Coordinates vendor evidence, notices, remediation, and follow-up.
Communications / Customer Service	Prepares approved customer communications and handles inquiries.

4. Cyber Incident Response Governance

Northline Brokerage Services, Inc. maintains this written incident response program as part of its customer information safeguards framework. The program is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. It applies to customer information in paper, electronic, and other forms, including information maintained by service providers on the firm's behalf.

The program begins when monitoring, employee reporting, a service-provider notice, or another reliable source indicates that unauthorized access or use has occurred or is reasonably likely to have occurred. The Incident Response Lead opens a case, assigns severity, preserves relevant records, and coordinates assessment, containment, customer-notice analysis, recovery, and closure.

- Detect: monitor security alerts, access anomalies, customer complaints, lost devices, vendor notices, and misuse reports.
- Respond: investigate, contain, control, communicate, and document decisions.
- Recover: restore approved services, remediate root causes, validate controls and access, and complete a post-incident review.

5. Assessment, Containment, and Control

For every suspected incident involving unauthorized access to or use of customer information, the response team assesses the nature and scope of the incident. The assessment identifies the date and method of access, affected accounts and users, duration, privileges obtained, systems involved, and whether data was viewed, copied, altered, transmitted, or destroyed.

The assessment must identify each customer information system that may have been affected and the types of customer information stored or processed in those systems. The team records whether sensitive customer information may be involved and identifies affected individuals when reasonably possible.

- isolate compromised hosts, accounts, applications, or network segments;
- disable or reset credentials and rotate keys or tokens;
- block malicious infrastructure and preserve monitoring;
- search for additional affected systems and unauthorized persistence;
- coordinate controlled shutdowns when needed to prevent further unauthorized access or use.

6. Notice to Affected Individuals

Compliance and Legal determine whether notice is required whenever sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. Notice is presumed unless a reasonable investigation of the facts and circumstances supports a documented determination that the information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

If the firm cannot identify which specific individuals were affected, it notifies all individuals whose sensitive customer information resides in the affected customer information system, except individuals the firm reasonably determines were not subject to unauthorized access or use.

The firm provides or ensures delivery of notice as soon as practicable and no later than 30 calendar days after becoming aware that unauthorized access to or use of customer information occurred or is reasonably likely to have occurred. Investigation and remediation continue in parallel and do not extend the outside deadline.

7. Notice Form and Delivery Standards

Each notice must be clear and conspicuous, written in understandable language, and transmitted by a method reasonably designed to provide actual written notice. Electronic delivery may be used for individuals who have agreed to receive communications electronically.

- a general description of the incident and the type of sensitive customer information involved;
- the incident date, estimated date, or date range, if reasonably possible to determine;
- a telephone number, email address or equivalent method, postal address, and the name of a specific office for questions and assistance;
- for account holders, a recommendation to review account statements and promptly report suspicious activity;
- an explanation of fraud alerts and how to place one;
- a recommendation to obtain credit reports from each nationwide credit reporting company and dispute fraudulent transactions;
- instructions for obtaining free credit reports;
- FTC and [usa.gov](https://www.ftc.gov) identity-theft guidance, encouragement to report identity theft to the FTC, and the applicable FTC website address.

8. Service Provider Oversight

The firm maintains and enforces written procedures for due diligence and ongoing monitoring of service providers that receive, maintain, process, or are permitted access to customer information. Reviews consider security controls, incident-response capability, subcontractor use, independent assurance reports, material changes, and known control failures.

Oversight is reasonably designed to ensure that service providers protect against unauthorized access to or use of customer information and notify the firm as soon as possible, but no later than 72 hours after becoming aware that a breach in security resulted in unauthorized access to a customer information system maintained by the provider.

Upon receipt of a qualifying provider notice, or upon independent detection of the incident, the firm immediately initiates its incident response program. A provider may deliver customer notices under a written agreement, but the firm remains responsible for ensuring that each required notice satisfies the firm's obligations and is timely delivered.

- document initial and periodic due diligence;
- track identified risks and remediation;

- maintain provider breach notices and related communications;
- verify completion and delivery when a provider sends customer notices on the firm's behalf.

9. Customer Information Security Controls

The safeguards program applies to customer information in the firm's possession and customer information handled or maintained on its behalf. It also applies to nonpublic personal information received from another financial institution about that institution's customers. Controls are selected to ensure confidentiality, protect against anticipated threats or hazards, and prevent unauthorized access or use that could result in substantial harm or inconvenience.

- Administrative safeguards: risk assessment, assigned ownership, workforce training, access approval, change management, service-provider oversight, and periodic control review.
- Technical safeguards: multi-factor authentication, least privilege, encryption in transit and at rest where appropriate, endpoint protection, vulnerability management, secure configuration, logging, monitoring, and tested backups.
- Physical safeguards: controlled office and records-room access, visitor management, locked storage, secure transport, clean-desk expectations, and destruction controls for paper and media.

10. Records Destruction Procedures

The firm properly disposes of consumer information and customer information by taking reasonable measures to prevent unauthorized access to or use of the information during and after disposal. Disposal occurs only after applicable retention, legal hold, contractual, and business requirements are satisfied.

- Paper records are placed in locked consoles and destroyed by cross-cut shredding or a vetted destruction provider.
- Electronic files are securely deleted using approved methods; encryption keys may be destroyed when cryptographic erasure is appropriate.
- Devices and removable media are inventoried, sanitized, or physically destroyed before reuse or disposal.
- Cloud repositories, backups, and service-provider systems are included in disposition instructions and verified when material customer information is involved.
- Certificates or confirmations of destruction are retained when a third party performs disposal.

11. Compliance Records and Retention

Compliance maintains true, accurate, and current records demonstrating implementation of the safeguards and disposal program. Records are indexed by incident, requirement, and responsible owner and are available for examination.

- current and prior written safeguards and disposal policies;
- detected unauthorized access or use, including assessment, response, containment, recovery, and closure records;
- notification investigations, determinations, supporting facts, and the basis for any no-notice decision;
- copies of customer notices and delivery records, including notices sent by service providers;
- written documentation from the Attorney General concerning any delay in notice;
- service-provider due diligence, monitoring, breach notices, remediation, contracts, and delegation agreements;
- records of disposal procedures and material destruction activities.

These records are preserved for three years in an easily accessible place. Legal holds and longer requirements supersede the ordinary schedule.

12. Logging and Investigation Records

The incident manager maintains a contemporaneous incident file containing alerts, system and identity logs, relevant exports, screenshots, investigation notes, affected-system and data inventories, decisions, approvals, containment steps, customer-notice analysis, provider communications, recovery tests, and closure documentation.

Relevant logs and volatile information are preserved promptly. Exports are stored in access-controlled case folders with source, collection time, custodian, and integrity information when material to the investigation. Routine log retention is not shortened while an incident, investigation, examination, or legal hold is open.

13. National Security and Public Safety Delay

Legal coordinates with appropriate regulators and law-enforcement agencies during significant incidents. Customer communications may be postponed when law enforcement requests a delay or when disclosure could interfere with an active investigation.

Legal records the request and advises management when external communications may resume.

14. Recovery, Remediation, and Validation

Recovery begins after the response lead confirms that immediate containment is stable. System owners restore services from approved configurations and backups, reset or reissue credentials, apply patches or configuration changes, and verify that unauthorized access paths have been removed.

Before returning a material customer information system to normal operation, the owner validates security logging, access permissions, data integrity, critical transactions, and required business functions. Remediation items are assigned owners and due dates and remain open until evidence of completion is reviewed.

- document restored systems and data sources;
- perform targeted monitoring for recurrence;
- confirm customer-service and notice obligations remain on track;
- complete a lessons-learned review and update procedures, safeguards, or service-provider requirements;
- obtain closure approval from the incident lead and Compliance.

15. Training, Testing, and Review

Personnel receive training appropriate to their roles. Employees are trained to report suspicious access, lost devices, misdirected information, customer complaints suggesting account compromise, and unusual service-provider communications.

The policy owner reviews this document at least annually and after material incidents, major system changes, regulatory developments, or significant service-provider changes. Tabletop exercises test escalation, evidence collection, containment, customer-notice decisions, vendor coordination, and service restoration.

16. Annual Privacy Notice Administration

The firm may rely on the annual privacy notice exception only while it discloses nonpublic personal information to nonaffiliated third parties solely under an applicable opt-out exception and has not changed the disclosure policies and practices described in the most recent customer notice.

If the exception no longer applies and a revised notice is required, the revised notice is treated as the initial notice for annual timing. If no revised notice is required, annual notices resume within 100 days of the change.

17. Appendix A - Incident File Minimum Contents

- incident identifier, discovery date, and awareness date;
- affected systems, business processes, customer information types, and individuals;
- investigation timeline, containment actions, and recovery steps;
- notification analysis, decision, approvals, and copies of notices;
- service-provider notices, contracts, communications, and remediation;
- logs, exports, screenshots, evidence sources, and preservation details;
- corrective actions, validation results, post-incident findings, and closure approval.

18. Appendix B - Customer Notice Quality Check

Check	Required review
Trigger and timing	Awareness date documented; outside date calculated; any authorized delay supported.
Affected population	Affected individuals identified or system-wide population addressed.
Required content	Incident, data types, date/range, contacts, account guidance, fraud alert, credit reports, FTC/usa.gov resources.
Delivery	Clear and conspicuous written notice using a method reasonably expected to provide actual notice.
Evidence	Final notice, approvals, delivery records, and provider confirmations retained.

Approval

Policy owner	Chief Compliance Officer	Date	March 3, 2026
Approving body	Management Compliance Committee	Version	2.7